

Governance Controls Framework for Safe & Responsible AI System Behavior

1. Purpose & Scope

This document defines the governance-level controls required to ensure safe, reliable, and responsible behavior from a general-purpose AI help chatbot. These controls address socio-technical harms identified in the AI Risk Register and are designed to prevent harmful outputs, reduce regulatory exposure, and maintain user trust.

The controls focus on **system behavior**, **content safety**, and **oversight**, rather than infrastructure or cybersecurity. They are intended for executive leadership, AI governance teams, compliance stakeholders, and safety engineering teams responsible for maintaining the model's risk posture.

2. Control Taxonomy Overview

The governance controls are organized into twelve categories:

1. Intent Classification
2. Refusal & Boundary Enforcement
3. Safe Alternative Generation
4. Multi-Step Reasoning Controls
5. Multi-Modal Safety Controls (limited applicability)
6. External Knowledge Source Governance
7. Output Validation & Action Authorization
8. Drift Monitoring & Regression Controls
9. Logging, Auditability & Human Oversight
10. Explainability & Transparency
11. User Identity & Context Sensitivity
12. Safety Consistency Controls
13. Safety Escalation & Tiered Response Controls

Each category addresses a distinct failure mode observed in harmful outputs and aligns with the risk register.

3. Control Categories & Detailed Controls

3.1 Intent Classification Controls

Purpose: Identify harmful, high-risk, or ambiguous user intent before generation.

Risks Addressed: Physical harm, fraud, coercion, unauthorized access, privacy violations.

Controls

- Upstream intent classifier detecting violence, self-harm, unauthorized access, fraud, coercion, medical/financial advice, and privacy violations.
- Detection of disguised intent (fictional framing, emergencies, “productivity hacks,” interpersonal conflict).
- High-risk domain triggers that escalate to stricter safety behavior or HITL review.

Governance Requirements

- Intent classification must run before generation.
- High-risk intent must never be passed directly to the model without safety routing.

Monitoring

- Weekly evaluation of classifier accuracy using regression test cases.
- Drift monitoring for false negatives.

3.2 Refusal & Boundary Enforcement

Purpose: Ensure the model declines harmful requests consistently and professionally.

Risks Addressed: Violence, unauthorized access, fraud, coercion, privacy violations.

Controls

- Hard refusal boundaries for violence, physical harm, illegal activity, unauthorized access, fraud, and coercion.
- Soft refusal boundaries for ambiguous or fictional harmful scenarios.
- Neutral, non-judgmental refusal language.
- Refusals must include grounding and safe redirection.

Governance Requirements

- Refusal patterns must be standardized and tested.
- Refusals must include grounding and safe redirection.

Monitoring

- Continuous regression testing of refusal consistency.
- Logging of refusal failures for review.

3.3 Safe Alternative Generation

Purpose: Provide constructive, safe alternatives when refusing harmful requests.

Risks Addressed: User frustration leading to jailbreak attempts, escalation of harmful intent.

Controls

- Domain-specific safe alternatives (conflict resolution, legal pathways, safety resources).
- Clear boundaries followed by actionable, safe next steps.
- Avoid moralizing or lecturing language.

Governance Requirements

- Safe alternatives must be reviewed by governance and legal teams.
- Alternatives must not inadvertently encourage harmful behavior.

Monitoring

- Monthly review of alternative suggestions for quality and safety.

3.4 Multi-Step Reasoning Controls

Purpose: Prevent harmful content from emerging through multi-step reasoning chains.

Risks Addressed: Disguised malicious intent, harmful escalation, “helpfulness drift.”

Controls

- Safety checkpoints between reasoning steps.
- Circuit breakers that halt generation if the chain moves toward harm.
- Multi-step refusal triggers for violence, unauthorized access, fraud, or coercion.

Governance Requirements

- Multi-step reasoning must be monitored for harmful trajectories.
- Safety checkpoints must be documented and auditable.

Monitoring

- Regression tests for multi-step harmful escalation.
- Drift monitoring for chain-of-thought safety degradation.

3.5 Multi-Modal Safety Controls (Limited Applicability)

Purpose: Address risks from multimodal content if the system is extended to images.

Applicability: The current chatbot does not process images. This section is included for future extensibility.

3.6 External Knowledge Source Governance Controls

Purpose: Prevent harmful or misleading external content (e.g., search results) from influencing model outputs.

Risks Addressed: Misinformation, harmful advice, biased content, adversarial SEO poisoning.

Controls

- Safety filtering of external search results before summarization.
- Neutral summarization mode that avoids reproducing harmful content verbatim.
- Domain-specific safety rules for medical, legal, financial, and physical safety topics.
- Disclaimers for high-risk domains.

Monitoring: Drift monitoring for changes in search engine behavior.

3.7 Output Validation & Action Authorization

Purpose: Ensure outputs do not encourage harmful real-world actions.

Applicability: The chatbot does not execute external actions. Controls focus on preventing outputs that *encourage* harmful actions.

Controls

- Validation rules preventing outputs that encourage physical harm, unauthorized access, fraud, or coercion.
- Safety filters for high-risk domains.
- No operational instructions for medical, legal, or financial actions.

Monitoring: Continuous evaluation of output safety using regression test cases.

3.8 Drift Monitoring & Regression Controls

Purpose: Ensure safety does not degrade over time.

Controls

- Drift detection using harm-sensitive metrics.
- Regression test suite integrated into CI/CD.
- Safety dashboards tracking refusal consistency, harmful output rates, and classifier performance.

Monitoring: Weekly drift review.

3.9 Logging, Auditability & Human Oversight

Purpose: Provide traceability and accountability for safety-critical interactions.

Controls

- Logging of high-risk prompts, refusals, and safety escalations.
- HITL review for ambiguous or high-risk cases.
- Audit trails for compliance with regulatory requirements.

Governance Requirements

- Logs must be retained according to enterprise policy.
- HITL reviewers must be trained in safety and compliance.

3.10 Explainability & Transparency Controls

Purpose: Ensure the system provides clear, understandable explanations for safety decisions, refusals, and high-risk interactions.

Controls

- Clear explanations when refusing harmful requests.
- Safety rationales must be neutral and accessible.
- High-risk domains must include disclaimers and safe alternatives.
- Internal explainability logs documenting refusal rationale.

Monitoring Quarterly review of explanation clarity and consistency.

3.11 User Identity & Context Sensitivity Controls

Purpose: Adjust safety posture based on user vulnerability signals.

Risks Addressed: Harm to minors, escalation of interpersonal conflict, unsafe advice to distressed users.

Controls

- Detection of distress signals, vulnerability cues, and interpersonal conflict.
- Stricter safety posture for minors or vulnerable users.
- Additional grounding and safe alternatives for emotionally charged prompts.

Monitoring Monthly review of context-sensitive safety behavior.

3.12 Safety Consistency Controls

Purpose: Ensure safety behavior is predictable and stable across contexts.

Risks Addressed: Inconsistent refusals, harmful outputs triggered by emotional or fictional framing.

Controls

- Consistency rules for refusals across similar prompts.
- Consistency across emotional, fictional, and ambiguous framings.
- Consistency across multi-step reasoning chains.

Monitoring Regression tests specifically targeting consistency.

3.13 Safety Escalation & Tiered Response Controls

Purpose: Define clear escalation pathways for high-risk interactions.

Controls

- Tier 1: Low-risk refusal (e.g., skipping school).
- Tier 2: Medium-risk refusal + grounding (e.g., unauthorized access).
- Tier 3: High-risk refusal + grounding + safe alternatives (e.g., fraud, coercion).
- Tier 4: Critical-risk refusal + grounding + HITL escalation (e.g., violence, self-harm).

Monitoring Audit of escalation accuracy and HITL involvement.

4. Control-to-Risk Mapping Matrix

A simplified mapping of controls to risks:

Control Category	AI-RISK-001	AI-RISK-002	AI-RISK-003	AI-RISK-004	AI-RISK-005	AI-RISK-006	AI-RISK-007	AI-RISK-008	AI-RISK-009
Intent Classification	✓	✓	✓	✓	✓	✓	✓	✓	✓
Refusal & Boundaries	✓	✓	✓	✓	✓	✓	✓	✓	✓
Safe Alternatives	✓	—	✓	—	✓	✓	✓	—	✓
Multi-Step Reasoning	✓	✓	✓	✓	✓	✓	✓	✓	✓
External Knowledge Governance	✓	—	✓	—	✓	✓	✓	✓	✓
Output Validation	✓	✓	✓	✓	✓	✓	✓	✓	✓
Drift Monitoring	✓	✓	✓	✓	✓	✓	✓	✓	✓
Logging & HITL	✓	✓	✓	✓	✓	✓	✓	✓	✓
Explainability	✓	✓	✓	✓	✓	✓	✓	✓	✓
Context Sensitivity	✓	—	✓	✓	✓	✓	✓	✓	✓
Safety Consistency	✓	✓	✓	✓	✓	✓	✓	✓	✓
Tiered Escalation	✓	✓	✓	✓	✓	✓	✓	✓	✓

5. Regulatory Alignment

These controls support compliance with:

ISO 42001

- A.6.1 Risk Management
- A.6.2 Safety Controls
- A.6.4 Data Governance
- A.6.5 Monitoring & Logging
- A.6.6 Human Oversight
- A.6.7 Transparency
- A.9.2 Incident Response

EU AI Act

- Risk management
- Data governance
- Technical documentation
- Logging
- Transparency
- Human oversight
- Post-market monitoring

6. Control Effectiveness & Residual Risk

Even with strong controls, residual risk remains in areas where:

- user intent is ambiguous
- external content is unpredictable
- multi-step reasoning may drift
- harmful content is framed as “helpful advice”
- emotional or high-pressure prompts distort safety behavior

Residual risk is monitored continuously and reviewed by governance and safety teams.

7. Governance Recommendations & Maturity Roadmap

To maintain and improve the system’s safety posture:

- Expand regression test coverage for disguised intent.

- Strengthen detection of emotional manipulation and high-pressure framing.
- Periodically retrain intent classifiers with new adversarial examples.
- Review safe alternative templates quarterly.
- Conduct quarterly safety audits aligned with ISO 42001.
- Maintain a cross-functional Responsible AI Committee for oversight.